第四课 PKI

PKI

基本概述

使用**公钥概念**和**密码技术**实施和提供安全服务的具有普适性的安全基础设施的**总称**。

1、PKI提供了一个安全框架，使各类构件、应用、策略组合起来为网络环境中的相关活动提供以下的安全功能：

- 身份识别与鉴别
- 数据保密性
- 数据完整性
- 不可否认性

2、目的

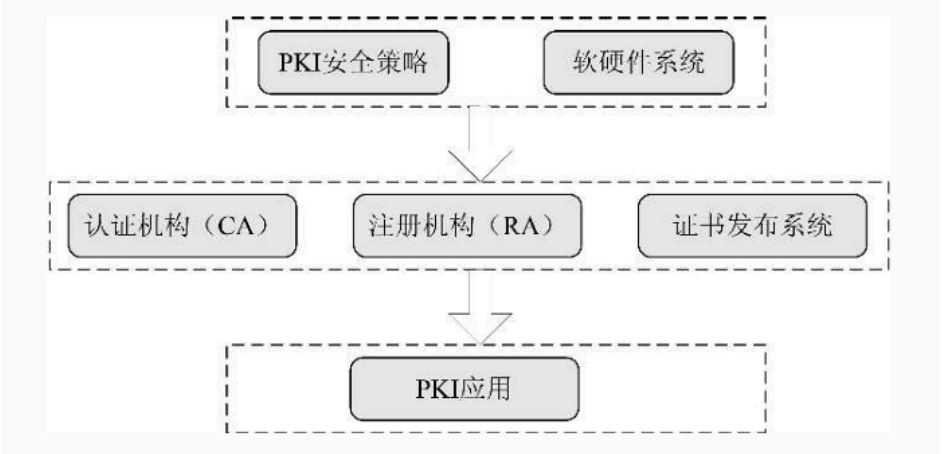
为了提供可信任的高效密钥和证书管理，以支持众多依赖于公钥的安全技术

3、作用

确保网上信息传递的安全、真实、完整和不可抵赖。 方便建立可信的网络环境，确保身份和信息的安全交换。→ 确认接收到的公钥是否属于发送者

组成要素

组织架构图：



1、PKI 安全策略

创建并定义了一个用于**实施信息安全**的策略，同时也定义了**密码系统的使用方法和原则**。

- CA的创建和运作方式
- 证书的申请、发行、接收和废除方式
- 密钥的产生、申请、存储和使用方式。

2、认证机构 CA

Certificate Authority，PKI的信任基础，它管理公钥的整个生命周期，必须是公众信任的、认可的、权威的第三方身份认证机构

作用：

- **签发和管理**证书
- 规定证书的**有效期**
- 通过发布**证书废除列表**（CRL）确保必 要时可以废除证书

3、注册机构 RA

提供用户和 CA 之间的一个接口，它获取并认证用户的身份，向 CA 提出证书请求。

作用：

- 收集用户信息
- 确认用户身份
- 证书发布成功后，通知与引导用户下载数字证书

❗ RA并不给用户签发证书，而只是对用户进行**资格审查**

4、证书发布系统

负责**发放**、**管理**和**展示**数字证书的平台。

目前一般要求证书发布系统可以 Web 方式与 Internet 用户交互，用于处理在线证书业务，方便用户对证书进行**申请、下载、查询、注销、恢复**等操作。

5、证书验证机构 VA

Validation Authority。在PKI中，VA是一个实体，根据X.509标准和 RFC 5280 中描述的机制提供用于**验证数字证书有效性**的服务。

VA一般由第三方来提供。

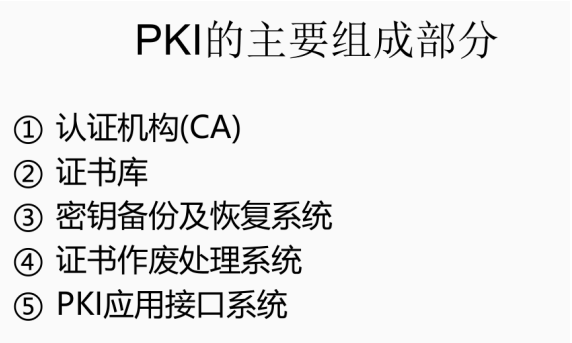
❗ 不参与制证，也不参与审核，它只负责**实时验证**。

6、PKI 应用

- Web 通信：服务器与浏览器
- 电子邮件：加密签名

- 信用卡交易
- SSL/TLS、IPSec、VPN

功能流程图：



证书库构建：支持**LDAP协议**的目录系统，用户或相应的软件通过LDAP协议访问证书库

认证机构 CA

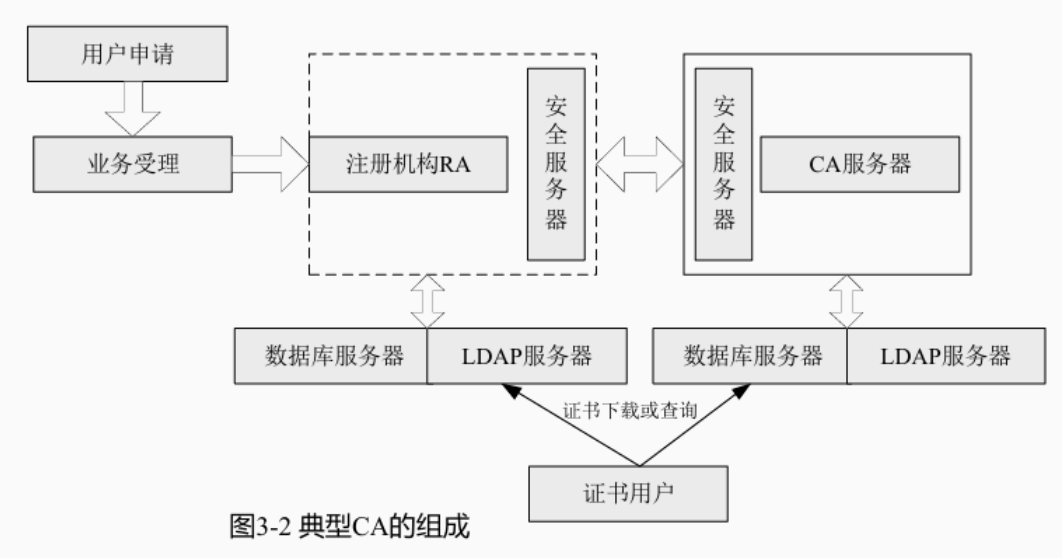


图3-2 典型CA的组成

1、CA服务器

是整个认证机构的核心，负责证书的签发。

CA首先产生自身的私钥和公钥，然后生成数 字证书，并且将数字证书传输给安全服务器。

CA还负责为操作员、安全服务器以及注册机构服务器生 成数字证书。

一般将CA服务器与其他服务器隔离，确保认证机构的安全。

2、LDAP 服务器

提供**目录浏览**服务，负责将注册机构服务器传输过来的用户信息以及数字证书加入服务器上。这样其他用户通过访问LDAP服务器就能够得到数字证书。

3、签名

证书签发：CA 用自己的**私钥**进行签名。

用户公钥：用户自己产生 / CA 替用户生成

签名算法：

- Hash 签名：生成摘要，确保内容完整性
- DSS 签名
- RSA 签名：私钥签名，公钥验证 → 只有 CA 能进行签发

PKI 相关标准

- 证书格式：X.509 v3标准
- 目录服务：LDAP
- PKCS系列标准：统一各类加密信息的格式（如证书申请、私钥导出、数字签名等），确保不同厂商的密码设备与软件之间能够实现**互操作性**。
- 交叉认证：PKIX group in IETF(RFC 2459)

证书

PKI采用**证书管理公钥**，通过第三方的可信任机构CA把用户的**公钥**和用户的**其他标识信息**捆绑在一起，在Internet或Intranet 上验证用户的身份。

数字证书的安全保障：确保四大网络安全要素

- 信息传输的**保密性**
- 数据交换的**完整性**
- 发送信息的**不可否认性**
- 交易者**身份的确定性**

X.509 证书格式



证书版本号（Version）
证书序列号（Serial Number）
签名算法标识符（Signature）
颁发机构名（Issuer）
有效期（Validity）
实体名称（Subject）
证书持有者的公开密钥信息（subject Public Key Info）
颁发者唯一标识符（Issuer Unique Identifier）
证书持有者唯一标识符（Subject Unique Identifier）
签名值（Issuer's Signature）

- **证书版本号（Version）**：标明是 X.509 的哪个版本（目前常用 v3），从0开始，v3 → 2
- **证书序列号 (Serial Number)**：由 CA 给证书分配的**唯一 ID**，用于在撤销列表（CRL）中精确锁定该证书。
- **签名算法标识符（Signature）**：指定由CA签发证书时所使用的签名算法。
- **颁发机构名 (Issuer)**：签发这张证书的 CA 的名字。包括国家、省市、地区、 组织机构、单位部门和通用名。
- **有效期 (Validity)**：证书的“生卒日期”，包含生效和失效时间，使用时必须检查。
- **实体名称 (Subject)**：证书持有者（持证人）的名字。
- **证书持有者的公开密钥信息 (Subject Public Key Info)**：这是证书最重要的部分，包含了**持有者的公钥值**以及**公钥所用的算法**。
- **颁发者唯一标识符 (Issuer Unique Identifier)**
- **证书持有者唯一标识符 (Subject Unique Identifier)**

  上面两个都是v2加入，可选，用于在同一个 CA 名称或持有者名称被多次重用时提供额外的唯一性区分。
- **签名值 (Issuer's Signature)**：这是 CA 用自己的**私钥**对上述所有信息（版本号到持有者标识符）进行加密后的“防伪印章”。

验证证书

A验证B：

1、验证 CA认证

- A收到B的证书，和 CA 的证书
- 通过CA**根证书**的里的**CA公钥**验证B证书的CA签名得到**Hash值H1**

- A将B的**证书前面内容**进行Hash得到**H2**
- **对比两个Hash值**，一致则证书通过。表示B的公钥是CA认证的

2、验证发送方

- 被验证方B发送一个测试数据+B**私钥签名**的 HASH 测试数据
- A收到后，将测试数据的HASH值与B**公钥验证**的签名数据比较，HASH值一致表示私钥掌握在B的手里，通过验证。

证书撤销

证书的撤销操作由CA完成，当CA接收到用户撤销证书的申请时，立即执行证书 撤销操作，同时通知用户证书的撤销情况。

实现方式：

- 利用**周期性发布**机制 → 证书撤销列表 CRL（ Certificate Revocation Lists）
- 利用**在线查询**机制 → 在线证书状态协议OCSP（Online Certificate Status Protocol）

证书撤销列表 CRL

证书可能在有效期内，因私钥泄露、信息变更变得不可信。

1、特点：

- 本身由CA签名担保
- 任何一个证书撤销以后，认证机构CA会通过**周期性**发布CRL的方式来通知各个相关方。
- CRL中并不存放撤销证书的全部内容，**只 存放证书的序列号**，以便提高检索速率。

2、证书格式：

证书版本号
签名算法
证书签发机构名
本次签发时间
下次签发时间
用户公钥信息
签名算法
签名值

- 本次签发时间：本次 CRL 签发时间

- 下次签发时间：CA 承诺**下一次更新并发布**新版 CRL 的时间点。
- 签名算法（第一个）：CA 在生成CRL时选择的算法，用于告诉系统该用什么工具来处理后面的信息。
- 签名算法（第二个）：紧挨着的签名值使用什么算法

3、缺点

- 存储分散
- 更新滞后
- 处理开销：证书撤销数量增加，CRL 变得越来越大，检索和处理它的速度会变慢。
- 客户端需要自己下载、存储并解析整个名单

在线证书状态协议OCSP

👉 OCSP对获得证书撤销信息的及时性要强， 一般用于**网上银行、网上证券**、电子政务中的某些关键部门。

1、特点

- **请求/响应模式**：客户端（如浏览器）生成一个包含**待查询证书 ID** 的请求，发送给 OCSP 响应器（Responder）。
- **实时反馈**：服务器在后台快速检查该证书的状态（有效/撤销/未知），并将结果返回给客户端。
- **无需下载名单**：客户端不需要关心整个列表，只需要获取针对这一个证书的结果即可，非常轻便。

2、优点

- **实时性强**：得到的信息总是当前证书的真实状态，没有“时差”。
- **流量小：**每一次查询只需要处理单个证书的信息，不需要像 CRL 那样传输整份巨型名单

3、缺点

- **不能完全取代 CRL**：OCSP 响应器可能出现故障，一定条件下仍需 CRL 作为**备份**。
- **服务器瓶颈**：因为是实时查询，如果访问量巨大，服务器容易成为瓶颈，且容易受到 **DoS（拒绝服务）攻击**。
- **性能消耗**：服务器需要为每一个响应生成大量的签名，这非常耗费系统性能。

轻型目录访问协议 LDAP

Lightweight Directory Access Protocol

why

1、why not 数据库存储&查询?

- 关系型数据库强调ACID特性，每当插入/更新数据，都要进行复杂的完整性检查、锁管理等，**性能较差**
- 用户权限一般只设置在表一级（整张用户表），而不是记录一级（单条记录）

2、why LDAP?

- 功能和数据库类似，但其数据主要是文本型字符
- 主要面向数据的查询服务，**不提供事务回滚机制**
- 目标与数据库不同：提供快速响应、大容量查询，提供多目录服务器的信息复制（将整个证书目录树在多台服务器之间进行**松散复制**）

X.500目录服务

目录服务的国际标准（理论鼻祖），全球性的、树状结构的目录系统，用来存储各种网络资源

1、**核心贡献**:

- **DN 标识名**：命名规则，颁发机构名&实体名称都基于 X.500 的 DN 结构，通过层级化的命名，保证了全球范围内证书持有者身份的唯一性。
- **树状结构基础**

2、特点

- 基于 **OSI** 体系结构，内容庞杂，开发和部署及其复杂，性能不高
- 每个分支代表一个部门，而这些部门可能散布在全世界不同的地点。
- 分区存储：“数据库”按部门拆分，分别存储在不同地方
- 分布式查询：先查本地分区，查不到再通过互联网跨节点查其他分区

  👉 提高查询效率

LDAP协议

在X.500基础上发展，一种基于 **TCP/IP** 的轻量级目录服务协议，它通过**树状结构**提供**快速、高效的数据检索**和**用户身份验证**功能，是企业构建统一身份管理和 PKI 证书分发服务的核心基础设施。

在 PKI 系统中，LDAP 主要扮演 **“证书发布系统”** 和 **“存储库”** 的角色:

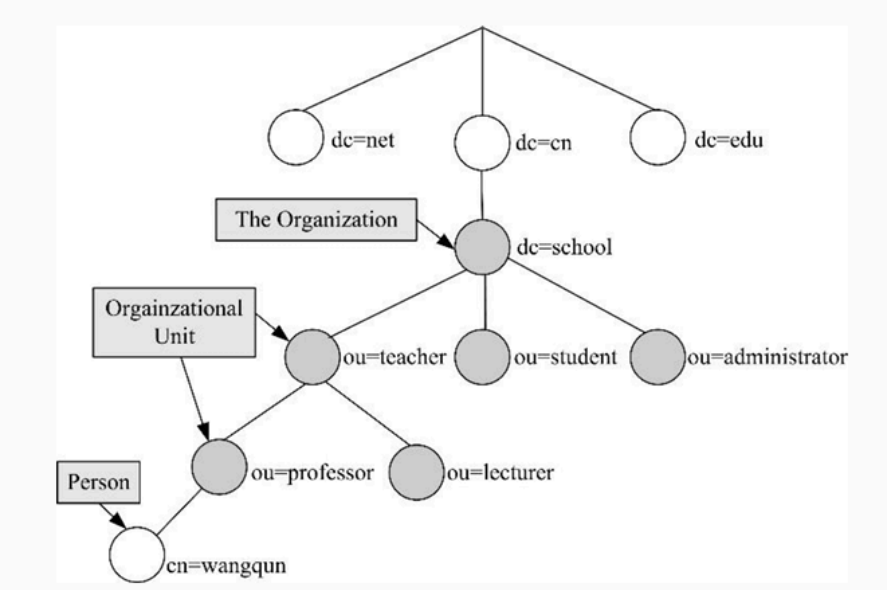
- CA 签发完证书后，会将证书发布到 LDAP 服务器中。
- 用户和服务器在进行身份验证时，可以通过 LDAP 协议快速检索到对方的数字证书或检查证书状态。

1、核心职能

- **存储数据**：以“树状结构”存储各类信息。
- **身份验证（认证）**：最常见用途。许多企业应用（如 Docker, Jenkins, VPN 等）都支持通过 LDAP 对接，实现“单一登录（SSO）”，即用户只需一套账号密码，就能在多个支持 LDAP 的系统中登录

2、特点

- **读多写少**：性能远超关系型数据库
- **条目（Entry）**：基本数据单元，类似关系数据库中表的记录
- **DN (Distinguished Name)**：每个条目的唯一标识名，类似文件系统中的绝对路径，用于精准定位某个数据。
- **DIT (Directory Information Tree)**：目录信息树，LDAP 组织数据的树状拓扑结构。
- **树状层级结构**：数据组织形式像DNS/文件系统（目录），符合人类对组织架构（部门->员工）的管理逻辑，且支持灵活的访问控制。



优点：

- 跨平台、标准协议
- 客户端程序品种多
- 应用程序添加LDAP支持很容易
- 存放位置对用户透明
- 安装简单，易于维护
- 使用ACL(访问控制列表)控制对数据的读写， 开发客户端时方便简单

CA 信任关系模型

信任模型主要阐述以下几个问题

- PKI用户信任的证书是怎样被确定的?

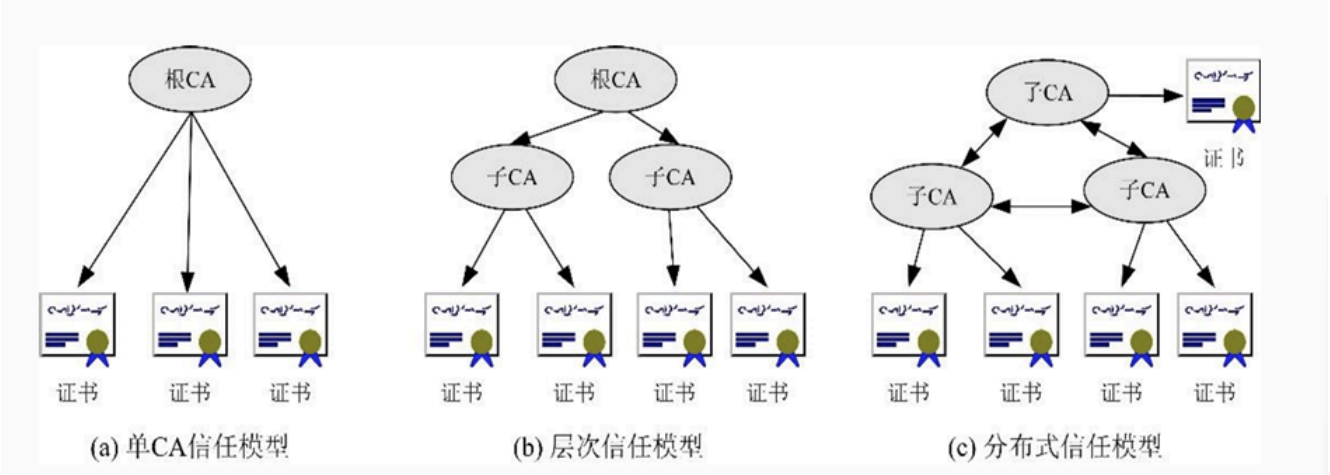
  通过**证书路径**确认，从信任锚出发逐级验证到目标用户的证书
- 这种信任是怎样被建立的?

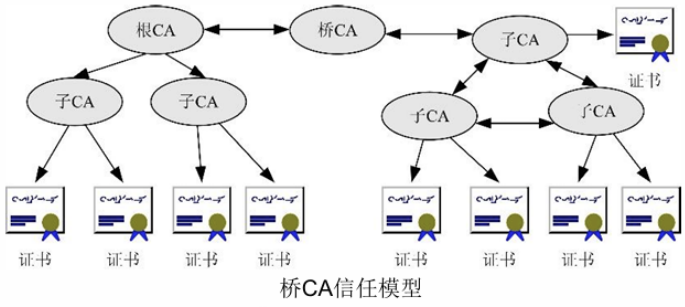
  通过“**数学签名**”与“**层次关系**”建立。
- 这种信任在一定环境下如何被控制?

  通过“**策略**（Policy）”与“**约束**（Constraint）”控制。

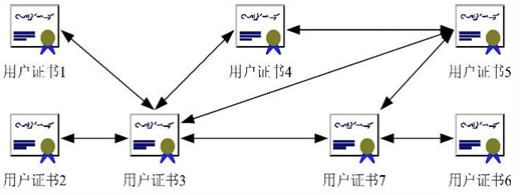
常用信任模型:

1、CA的严格层次结构模型

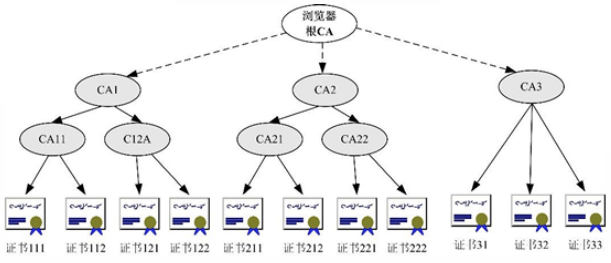




桥CA信任模型



以用户为中心的信任模型



Web信任模型